

HACKBACK 2026 · REVERSE-ENGINEER & REBUILD

Excalidraw, Rebuilt

Instant, zero-account, end-to-end encrypted whiteboarding. Local-first, so your sketches stay yours and the server never reads them.



THE FIX

Lock down open rules

Firebase let anyone overwrite or wipe any room.



NEW ADDITION

Burn-after-read links

E2E share links that self-destruct after N views.

Whiteboards still demand accounts and trust

PROBLEM STATEMENT

For developers and creators stuck with heavyweight diagramming tools that demand logins and slow setups, we deliver instant, zero-account, end-to-end encrypted real-time sketching with local-first persistence, unlike cloud whiteboards that lock drawings behind accounts and server-side tracking.

Who: engineers & architects · designers & PMs · devs embedding a canvas

0

accounts needed to start drawing

128-bit

AES key, kept only in the URL #hash

<100 ms

target sync between live peers

CORE FLOW: NO LOGIN AT ANY STEP

01



Open

Canvas ready at / with no sign-up

02



Draw

Shapes, arrows, text, free-draw

03



Auto-save

IndexedDB after every stroke

04



Go live

#room=id,key with live cursors

05



Share

Encrypted #json=snapshot link

06



Export

PNG, SVG or .excalidraw JSON

5 verified gaps in the original

1	SECURITY WE FIX THIS	Firestore rules allow unauthenticated writes to any document, with no payload size check.	firebase-project/firestore.rules:5
2	CORRECTNESS	Simultaneous room joins race on local state with no atomic reconciliation gate.	excalidraw-app/App.tsx:332-345
3	VALIDATION	The #url= loader fetches remote scenes with no HTTPS enforcement or size limit.	excalidraw-app/App.tsx:307-310
4	UX / ERRORS	Bad or mismatched keys silently fall back to legacy decryption, then show a generic alert.	excalidraw-app/data/index.ts:230-241
5	STORAGE	Hitting the storage quota sets a flag but never backs up the unsaved work.	excalidraw-app/data/LocalData.ts:129-131

Each claim was checked against the source at file:line. Full list in docs/GAPS.md and docs/OBSERVATIONS.md.

The fix: lock down the open Firebase rules

BEFORE • ORIGINAL

```
// firestore.rules
match /{document=**} {
  allow get, write: if true;
  allow list: if false;
}
```

write = create + update + delete. Anyone holding a room ID can overwrite or wipe it, and upload a payload of any size.

storage.rules:4-9 leave /rooms and /shareLinks just as open.



AFTER • OUR REBUILD

```
match /scenes/{roomId} {
  allow get: if true;
  allow create: if valid();
  allow update: if valid() &&
    request.resource.data.sceneVersion
      >= resource.data.sceneVersion;
  allow delete, list: if false;
}
function valid() {
  let d = request.resource.data;
  return d.keys().hasOnly(
    ['sceneVersion', 'iv', 'ciphertext'])
    && d.ciphertext.size() < 2097152;
}
```

Schema-checked only sceneVersion, iv, ciphertext

Size-capped scenes under 2 MB; files capped too

No wipes or rollbacks no deletes, version never goes back

New: burn-after-read sketches

End-to-end encrypted share links that self-destruct after N views or a timer. The server never sees the drawing, and after the last view it no longer stores it either.



1 Pick a fuse

1 view, 5 views, 1 hour or 24 hours, chosen at export time.



2 Encrypt locally

Same deflate + AES-GCM pipeline. Key lives only in `#burn=id,key`.



3 Claim atomically

A Cloud Function transaction checks expiry, decrements views, returns ciphertext.



4 Burn

Last view or TTL deletes the blob. Late visitors see “This sketch has burned.”

WHY IT'S UNIQUE

Disappearing chat exists. Disappearing diagrams that the server can't read don't. Use it for incident post-mortems, interview whiteboards and sensitive architecture.

WHY THE FIX MATTERS HERE

Burn links live in a collection that clients can't touch (allow read, write: if false). The Cloud Function is the only way in, so nobody can skip the view counter.